
Operational Policy

Policy title: Information Technology Risk Management Policy

Policy number: ODHSOHA 090-016

Original policy date: 06/06/2022

Last update: 07/01/2025

Approved by: Kris Kautz, OHA and Seth Lyon, ODHS

Purpose

The Oregon Department of Human Services (ODHS) and Oregon Health Authority (OHA) are committed to ensuring the confidentiality, integrity, and availability of information assets and systems by safeguarding their physical security and protecting those assets from unauthorized access, modification, destruction, or disclosure. The purpose of this policy is to foster the practice of risk-based decision-making processes for ODHS and OHA information assets.

Description

This policy establishes the framework for the agency's information technology risk management program, which includes risk assessment, risk response, and risk monitoring.

Applicability

This policy applies to all ODHS and OHA staff, including full-time, part-time, contingent, temporary, and limited duration employees, volunteers, trainees, and interns. The requirements of this policy also apply to contractors, grantees, and partners in their delivery of goods or services to or on behalf of either agency, as required under the applicable contract, grant, or other form of agreement.

As keepers of the public trust, all ODHS and OHA staff play a vital role in upholding state and agency policies, administrative rules, and state and federal laws. ODHS and OHA are committed to exceptional public and customer service. The agencies are dedicated to maintaining standards of exceptional service and trust staff to do the same. Failure to follow policies, rules and laws may result in beginning a personnel process to consider formal action as appropriate, including progressive discipline up to and including dismissal from state service.

Policy

1. The Information Security and Privacy Office (ISPO), shall develop, implement, and maintain an ODHS and OHA Information Technology Risk Management Plan in collaboration with program directors, system administrators, and information system owners to frame agency risk and establish a risk context¹.
2. The ISPO IT Risk Management team shall review and update the ODHS and OHA Information Technology Risk Management Plan every two years or when significant changes occur in the business or regulatory environment.
3. The ISPO IT Risk Management team shall implement an information technology risk management process (090-016-01 Information Technology Risk Management Process) to:
 - a. Report information technology related risk.
 - b. Assess information technology related risk.
 - c. Respond to information technology related risk.
 - d. Monitor information technology related risk.
4. Active risks without immediate remediation will be assigned a risk owner who is responsible for providing updates to the ISPO IT Risk Management team at least quarterly.

References

[45 CFR 160 General Administrative Requirements](#)

¹ National Institute of Standards and Technology SP 800-39

[45 CFR 164 Security and Privacy](#)

[IRS Publication 1075, Tax Information Security Guidelines for Federal, State and Local Agencies](#)

[Acceptable Risk Controls for Affordable Care Act \(ACA\), Medicaid, and Partner Entities \(ARC-AMPE\)](#)

[National Institute of Standards and Technology \(NIST\) 800-30 Rev. 1 Guide for Conducting Risk Assessments](#)

[National Institute of Standards and Technology \(NIST\) 800-37 Rev. 2 Risk Management Framework for Information Systems and Organizations](#)

[National Institute of Standards and Technology \(NIST\) 800-39 Managing Information Security Risk: Organization, Mission, and Information System View](#)

[National Institute of Standards and Technology \(NIST\) 800-53 Rev. 5 Security and Privacy Controls for Information Systems and Organizations](#)

[NIST White Paper: Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1, April 16, 2018](#)

[NIST Interagency Report 8170 Approaches for Federal Agencies to Use the Cybersecurity Framework](#)

[Social Security Administration \(SSA\) Electronic Information Exchange Partner Technical System Security Requirements](#)

[Statewide Information Technology \(IT\) Control Standards](#)

[ODHSOHA Agency Information Security Plan](#)

[ODHSOHA 090-006-01 Information Security Risk Assessment Process](#)

[ODHSOHA 090-006-02 Information Security Risk Assessment Process Map](#)

[ODHSOHA Information Technology Risk Management Program](#)

[ODHSOHA 090-016-01 Information Technology Risk Management Process](#)

[ODHSOHA 090-016-01 Information Technology Risk Management Process Map](#)

[ODHSOHA 090-007-01 Continuous Vulnerability Assessment Process](#)

Related policies

[ODHSOHA 090-006 Information Security Risk Assessment Policy](#)

Contact

Information Security and Privacy Office (ISPO)

ispo.inforisk@odhs.oregon.gov

This policy shall be reviewed at least once every year to ensure relevance.

Policy history

Version 1 OHDSOHA 090-016 established 06/06/2022

Version 2 ODHSOHA 090-016 revised 09/11/2023

Version 3 ODHSOHA 090-016 revised 07/01/2025

Version 4 ODHSOHA 090-016 revised 07/01/2026

Keywords

Risk assessment, risk management plan, risk register

You can get this document in other languages, large print, braille or a format you prefer free of charge. Contact Publications and Creative Services at dhs-oha.publicationrequest@odhsoha.oregon.gov or 503-373-1342. We accept all relay calls.